

CONFIDENTIAL · COMPLIANCE REVIEW

레몬헬스케어 AI Agent 기획안 규제·법률 적합성 평가 보고서

건강의 신 연동 AI 복약·영양 관리 Agent 서비스

— 6개 Agent 기능별 위반 가능성 평가 및 상세 구현·회피 전략 —

발주처

(주)레몬헬스케어

수행 주체

경북대학교 KDT AI/빅데이터

전문가 양성 과정 — Lemon-Aid

문서 버전 / 작성일

v1.0 / 2026.05.08

목 차

Part I. 핵심 요약 (Executive Summary)

Part II. 적용 법규 지도

Part III. 6개 Agent별 위반 가능성 평가

Part IV. 부가 기능 평가

Part V. 우선순위별 위험 매트릭스

— Part VI 이하 — 상세 구현 방안 및 회피 전략

Part VII. Agent #1 — 영양제·복약 분석 상세 설계

Part VIII. Agent #3 — 실시간 건강 모니터링 상세 설계

Part IX. Agent #4 — 가족 케어 동의 UX 설계

Part X. Agent #6 — 진료기록 요약 마이데이터 연동 설계

Part XI. 종합 권고 및 단계별 로드맵

Part I. 핵심 요약 (Executive Summary)

한 줄 결론

PDF 기획안의 6개 Agent 중 2개(#1·#3)는 의료기기 허가가 필요할 수 있는 고위험 영역이며, 2개(#4·#6)는 개인정보보호법·마이데이터 절차를 정확히 따르면 합법 구현이 가능합니다. 나머지 2개(#2·#5)는 표준 절차로 가능하나, 2025년 1월 시행된 디지털의료제품법으로 규제 환경이 근본적으로 변화한 만큼 기획 단계에서 신고/허가 트랙을 선제적으로 결정해야 합니다.

주요 발견 사항

기능	위험도	핵심 이슈
Agent #1 영양제·복약 분석	높음	"환자 복용약 기반 영양제 적합성 판단" → SaMD(소프트웨어 의료기기) 분류 가능성. 약사법 § 68 의약품 효능 설명 위반 가능
Agent #2 복약·일정 관리	낮음	사용자 입력 기반 알람 → 거의 전면 합법
Agent #3 실시간 건강 모니터링	높음	"혈압 급상승 자동 감지·심박 이상 알림" → 의료기기법 SaMD 해당. 식약처 허가 대상
Agent #4 가족 케어	중간	제3자(보호자) 민감정보 제공 → 항목별 별도 동의 필수. 위반 시 5년 이하 징역 또는 5천만원 이하 벌금
Agent #5 건강 점수·리워드	중간	경품 종류 제한. 특정 의료기관 진료권은 의료법 § 27의2 위반
Agent #6 진료기록 요약	중간	'건강정보 고속도로' 마이데이터 채널 사용 시 합법. 자체 EMR 직접 접근은 불가

2025년 시점의 신규 규제 환경

디지털의료제품법 (2025.01.24 시행)

이전 컴플라이언스 분석 시점에는 적용되지 않았던 법령으로, 디지털의료제품을 ① 디지털의료기기 ② 디지털융합의약품 ③ 디지털의료·건강지원기기 3가지로 분류합니다. 특히 ③ 디지털의료·건강지원기기 조항은 **2026.01.24 시행 예정**으로, 건강관리 앱도 일정한 신고·성능인증 절차를 거쳐야 할 가능성이 있습니다. 본 프로젝트의 Agent #1·#3은 이 분류 검토가 핵심입니다.

Part II. 적용 법규 지도

본 기획안에 적용되는 법규·가이드라인은 다음 8가지입니다. 이 중 2건은 2025년 신규 시행 또는 개정되었습니다.

#	법규/가이드라인	시행/개정	본 기획안에 미치는 영향
1	의료법 (§ 17, § 27, § 27의2, § 56)	기존	"진단·처방·치료" 표현 금지, 무면허 의료행위 처벌, 특정 의료기관 알선 금지
2	약사법 (§ 47, § 61, § 63, § 68)	기존	의약품 추천·약물 상호작용 안내 제한 (약사 면허자 영역)
3	건강기능식품법 (§ 16, § 18)	기존	식약처 인정 원료만 추천, 기능성 표현은 식약처 고시 그대로 사용
4	개인정보보호법 § 23 (민감정보 처리 제한)	2025.03.13 개정	건강정보는 다른 동의와 별도의 동의 필수. 위반 시 매출액 3% 이내 과징금
5	디지털의료제품법 (신규)	2025.01.24 시행	임상적 의사결정 지원 기능은 디지털의료기기 분류 가능. 허가·GMP 인증 필요
6	디지털의료·건강지원기기 조항	2026.01.24 시행 예정	건강관리 앱도 신고·성능인증 의무 가능성
7	비의료 건강관리서비스 가이드라인 2차	2022.09	만성질환자 대상은 "의료인 진단·처방·의뢰 범위 내" 포괄 허용
8	식품등의표시·광고에관한법률 § 10	기존	리워드 이벤트 시 건기식 광고 사전 심의

핵심 변화 — 디지털의료제품법의 등장

2025년 1월 24일 시행된 디지털의료제품법은 기존 의료기기법 체계로 규율하기 어려웠던 첨단 디지털 의료기술의 안전성·유효성 확보를 위해 제정된 법령입니다. 본 프로젝트의 Agent #1·#3과 직접적으로 연관됩니다.

분류	정의	본 프로젝트 매핑
① 디지털의료기기	디지털 기술이 적용된 의료기기 (질병 진단·치료·예방·관리 목적)	Agent #1의 "약물 상호작용 판정", Agent #3의 "심박 이상 자동 감지" 가능성 있음
② 디지털융합의약품	의약품과 디지털 기술이 결합된 제품	해당 없음
③ 디지털의료·건강지원기기	의료기기에 해당하지 않는 건강관리 목적의 디지털 제품 (2026.01.24 시행)	일반 건강관리 앱 대부분이 해당. 신고·성능인증 절차 검토 필요

Part III. 6개 Agent별 위반 가능성 평가

● Agent #1 — 영양제·복약 분석 Agent

기획서의 기능: 영양제 사진 분석 → 환자 복용약·만성질환 정보 기반 적합성 판단 → "혈압약 복용 중이므로 이 성분은 주의 필요" 식의 안내

검토 영역	위반 가능성	근거
의료기기 분류 (디지털의료제품법)	● 높음	"약물-영양제 상호작용 판단"은 임상적 의사결정 지원 → SaMD 해당 가능성
약사법 § 68 (의약품 효능 설명)	● 높음	의약품의 작용·상호작용 설명은 약사 면허자 영역
의료법 § 27 (무면허 의료행위)	● 중간	"복용 가이드 제공"이 처방으로 해석될 위험
건강기능식품법 § 18	● 중간	식약처 인정 기능성 표현만 사용해야

⚠ 핵심 충돌점

PDF 기획안의 핵심 메시지인 "제품 정보가 아니라, 환자의 진료 기록과 복용약 정보를 바탕으로 영양제 복용 위험을 분석"은 임상적 판단 영역에 진입합니다. 환자 개인 데이터 기반의 위험도 판정 기능은 의료기기 허가가 필요할 수 있습니다.

● Agent #3 — 실시간 건강 모니터링 Agent

기획서의 기능: 혈압/심박수 모니터링 → 혈압 급상승·심박 이상 감지 → 위험 알림 → 보호자 자동 알림

검토 영역	위반 가능성	근거
의료기기법 (혈압 측정 SaMD)	● 높음	식약처는 이미 모바일 앱 혈압 측정 SaMD 허가 사례 보유. 혈압 데이터 기반 위험 판정도 의료기기 해당 가능
의료법 § 27 (진단)	● 중간	"위험 신호 감지"로 표현 변경해도 진단 행위로 해석 위험
의료법 § 17의2 (응급상황 책임)	● 중간	위험 알림 미발송으로 인한 사고 시 손해배상 책임

💡 PDF 기획서의 좋은 인식

PDF에 이미 "이 기능은 '진단'이 아니라 위험 신호를 감지하고 의료진 상담을 권유하는 기능으로 정의하는 것이 적절"이라고 적시. 다만 **표현만 바뀌도 알고리즘 자체가 의료기기 판단의 근거가 됩니다** — Part VII에서 회피 전략 상세 제시.

● Agent #4 — 가족 케어 Agent

기획서의 기능: 보호자(자녀)에게 부모님의 복약률·진료기록·병원 일정·건강 상태 공유

검토 영역	위반 가능성	근거
개인정보보호법 § 23 (민감정보)	● 높음	다른 개인정보 처리 동의와 별도의 동의 필수. 위반 시 5년 이하 징역 또는 5천만원 이하 벌금
개인정보보호법 § 17 (제3자 제공)	● 높음	본인이 아닌 가족(보호자)은 법적으로 제3자 → 별도 동의 필수
의료법 § 21 (진료기록 비밀유지)	● 중간	보호자가 진료기록 받을 시 본인 동의 절차 필수

● Agent #6 — 진료기록 요약 Agent

기획서의 기능: 환자의 최근 진료 기록을 AI가 자동 요약 → 다른 병원 방문 시 보여줄 차트 생성

검토 영역	위반 가능성	근거
의료법 § 21 (진료기록 열람)	● 중간	본인 열람은 합법, but 의료기관 EMR 직접 접근은 별도 절차 필요
개인정보보호법 § 23	● 중간	진료기록은 민감정보
의료법 § 17 (진단서 발급)	● 낮음	AI 요약은 "진단서"가 아닌 "정보 요약" — 표현 주의 시 회피 가능

✓ 합법 구현 경로

이 기능은 자체 EMR 직접 접근이 아닌 '**건강정보 고속도로(MyHealthway)** 마이데이터 채널로 구현해야 합니다. 2025년부터 47개 상급종합병원 전체가 참여하며, 레몬헬스케어는 이미 LDB-E 플랫폼과 건강정보 고속도로 사업에 참여 중이므로 회사 인프라 활용 가능성이 가장 높은 영역입니다.

● Agent #5 — 건강 점수·리워드 Agent

기획서의 기능: 복약률·영양제 분석 사용·건강 지표 관리 → 응모권 지급 → 매달 이벤트 참여

검토 영역	위반 가능성	근거
건강기능식품법 § 18 (허위·과대광고)	● 중간	응모 경품으로 영양제·건기식 제공 시 광고 심의
식품등의표시광고법 § 10 (광고 사전심의)	● 중간	건기식 광고는 자율심의기구 사전 심의 대상
의료법 § 27의2 (의료기관 알선)	● 높음	리워드로 특정 병원 진료 인센티브 제공 시 알선 행위 → 형사처벌
사행행위 등 규제법	● 낮음	무작위 응모 추첨 자체는 사행성 미해당 (소비자 비용 부담 없을 시)

● Agent #2 — 복약·일정 관리 Agent

기획서의 기능: 약 복용 알람, 병원 방문 일정, 캘린더 연동, 복약 누락 재알림

검토 영역	위반 가능성	근거
의료법	● 낮음	알람은 진단·처방이 아닌 단순 리마인더
약사법	● 낮음	복용 시간 안내일 뿐 효능·약물명 추천 아님
개인정보보호법	● 낮음	복약 정보는 민감정보지만 본인 사용 한정

Part IV. 부가 기능 평가

기능	위험도	평가
영양제 사진 촬영 화면	● 낮음	일반 카메라 기능
분석 결과 화면	● 중간	Agent #1과 동일한 표현 가이드 적용
음성 안내 (어르신용)	● 중간	TTS 자체는 문제없음. 단, 음성 내용도 표현 가이드 동일 적용 — 음성으로 "병이 있습니다" 발화 시 진단 표현
가족 공유 화면	● 중간	Agent #4 동의 절차 적용
캘린더·알람 연동	● 낮음	OS 권한 요청 표준 절차
건강 점수·리워드 화면	● 중간	Agent #5 — 경품 종류 검토
병원 이동용 요약 차트	● 중간	Agent #6 — 본인 외 자동 전송 금지

Part V. 우선순위별 위험 매트릭스

합법 영역에서 작동	표현 가이드 필수	● 즉시 조정 필요 Agent #1 (약물 상호작용) Agent #3 (위험 알림) Agent #4 (가족 케어 — 미동의시)
정상 운영	● 구현 시 주의 Agent #6 (진료기록 요약) Agent #5 (리워드) 음성 안내 / 가족 공유	의료기기 분류 가능
● 표준 절차로 가능 Agent #2 (알람) 일반 OCR / UI 기능 캘린더 연동	합법	합법

↑ 영향도 (위) · 합법성 (좌→우) →

Part VI. 우선 대응 필요 사항 요약

● 즉시 조정 (학생 프로젝트 8주 범위)

1. **Agent #1** 약물 상호작용 분석 → 개인화된 위험도 판정을 "식약처 DUR(의약품 안전사용 정보) 일반 정보 안내" 형태로 전환
2. **Agent #3** 실시간 위험 알림 → 자동 위험 판정을 사용자 자가 임계치 설정 기반 알림으로 한정
3. **Agent #4** 가족 케어 → 부모님 본인의 항목별 별도 동의 + 동의 능력 확인 절차 구현

● 보완 필요 (구현 시 주의)

1. **Agent #6** 진료기록 요약 → 건강정보 고속도로 API를 통한 마이데이터 채널 사용 (자체 EMR 우회 불가)
2. **Agent #5** 리워드 → 경품 종류 사전 검토 (특정 병원 진료권·의약품 제외)
3. **음성 안내** → 음성 콘텐츠도 텍스트와 동일한 표현 가이드 검수

본 보고서의 **Part VII ~ Part X**에서는 위 4개 위험 Agent(#1, #3, #4, #6)에 대한 **구체적 구현 방안과 회피 전략**을 단계별로 상세히 제시합니다.

Part VII. Agent #1 영양제·복약 분석 — 상세 구현 방안 및 회피 전략

1. 회피 전략의 핵심 원리 — "임상적 판단 → 정보 매개"로의 전환

의료기기·약사 면허 영역으로 분류되는 핵심은 "개별 환자의 데이터를 입력받아 그 환자에게 특화된 위험도를 산출"하는 행위입니다. 이를 다음과 같이 전환하면 합법 영역으로 이동할 수 있습니다.

❌ 의료기기·면허 영역 (위반 가능)

시스템: "고객님의 혈압약(아모디핀)과 이 영양제의 칼륨 성분이 상호작용할 수 있어 위험합니다."

▶ 환자 데이터 입력 → AI가 위험도 판정 → 사용자 맞춤 결론 출력

✅ 정보 매개 영역 (합법)

시스템: "이 영양제에 포함된 칼륨 성분에 대해, 식약처 DUR 데이터베이스에는 다음과 같은 일반 안내가 있습니다: '일부 혈압약과 함께 복용 시 약사 상담 권장'. 자세한 내용은 의료진과 상담하세요."

▶ 영양제 성분 표시 → 식약처 공식 정보 단순 인용 → 의료진 상담 유도

2. 합법 구현 아키텍처 (3단 분리 설계)

1 Layer 1 — 라벨 OCR/파싱 (전면 합법)

영양제 사진을 OCR로 처리하여 제품명·성분명·함량을 추출. 이는 라벨에 적힌 정보의 단순 디지털화로, 어떤 면허도 필요하지 않음.

2 Layer 2 — 공식 DB 조회 (정보 제공)

추출된 성분명을 식약처 건강기능식품 원료 DB, DUR API 등 공공 데이터에 그대로 조회. 사용자에게는 "공식 자료에 따르면 이 성분은~" 형태로 인용.

3 Layer 3 — 의료진 상담 유도 (책임 이전)

개인 맞춤 판단이 필요한 경우 "의사·약사 상담을 권장합니다"로 명확히 종결. 시스템은 결론을 내리지 않음.

아키텍처 다이어그램



3. LLM 시스템 프롬프트 설계 (회피 전략의 기술적 구현)

Claude API 등 LLM 호출 시 다음 시스템 프롬프트를 적용하여 위반 응답을 사전 차단합니다.

당신은 한국 의료법·약사법·건강기능식품법을 엄격히 준수하는
영양제 정보 어시스턴트입니다. 다음 규칙을 절대 위반하지 마세요.

절대 금지 표현

1. "당신은 ○○입니다" 같은 진단성 단정
2. "이 약을 드세요/끓으세요" 같은 처방·복약 지시
3. "00 의약품 이름" 직접 언급 (성분명 일반 정보는 가능)
4. "치료", "재활", "발병위험도", "사망위험도" 단어 사용
5. "확실히", "보장합니다" 같은 효과 단정 표현

응답 의무 사항

1. 영양제 성분 정보는 라벨 인용 + 식약처 공식 자료만 인용
2. 만성질환·복용약 정보가 입력되어도 "개인 위험도 판정"하지 말 것
3. 모든 응답 마지막에 다음 문구 부착:
"본 정보는 일반적인 건강 안내이며, 의료적 진단·처방을 대체하지 않습니다.
질환·복용약이 있는 경우 반드시 의사·약사와 상담하세요."

응답 템플릿

[성분 정보] → [식약처 공식 기능성 표현] → [일반 주의사항] → [전문가 상담 권장]

입력 예시: "고혈압이 있는데 이 칼륨 영양제 먹어도 돼?"

올바른 응답:

"이 영양제에는 칼륨이 200mg 함유되어 있습니다.
식약처 자료에 따르면 칼륨은 '체내 삼투압 조절에 도움'을 줄 수 있는 성분으로 인정되어 있습니다.
일반적으로 일부 혈압약(칼륨보존이뇨제, ACE억제제 등)과 함께 복용 시 주의가 필요할 수 있다는
공식 안내가 있습니다. 본인의 복용약과의 적합성은 의사·약사와의 상담으로 결정하세요."

본 정보는 일반적인 건강 안내이며...(면책 고지)"

4. 표현 가이드 — 자동 검출 정규식

LLM 응답에 금지 표현이 출현했을 때 백엔드에서 자동 차단·재생성하는 후처리 단계입니다.

```
BANNED_PATTERNS = [
    r'당신은\s.+입니다',          # 진단성 단정
    r'.+(을|를)\s+(드세요|끓으세요|복용하세요)', # 처방
    r'(치료|재활|발병위험도|사망위험도)',        # 의료 전용어
    r'00\s*(의약품|약품)\s*(드세요|복용)',      # 의약품 추천
    r'(확실히|반드시)\s+(낫|좋아|효과)',        # 효과 단정
]

def safe_response(llm_text):
    for pattern in BANNED_PATTERNS:
        if re.search(pattern, llm_text):
            log_violation(pattern, llm_text)
            return regenerate_with_stricter_prompt()

# 면책 고지 자동 부착
if "전문가 상담" not in llm_text:
    llm_text += "\n\n" + DISCLAIMER
return llm_text
```

5. UI 구현 — "정보 카드" 형태로 변경

"이 영양제 먹어도 돼?"라는 질문에 시스템이 직접 답변하는 챗봇 형태에서, 다음과 같은 **3단 정보 카드**로 UX를 변경하면 의료기기 분류 위험을 크게 낮출 수 있습니다.

카드	표시 내용 (예시)	법적 위치
 카드 ① 성분 정보	"칼륨 200mg, 비타민 C 500mg, 마그네슘 100mg"	라벨 단순 표시 — 합법
 카드 ② 식약처 공식 안내	"칼륨: '체내 삼투압 조절에 도움' (식약처 인정 기능성)"	공공 정보 인용 — 합법
 카드 ③ 전문가 상담 안내	"복용 중인 약이 있으신가요? 약사·의사 상담을 권장합니다." [상담 안내 버튼]	책임 이전 — 합법

✓ 발표 시 강조 포인트

"우리 서비스는 AI가 결론을 내리는 것이 아니라, **분산된 공공 정보를 환자가 한눈에 볼 수 있도록 모아주고, 최종 판단은 전문가에게 맡기는 정보 큐레이션 서비스**입니다." 이 메시지가 의료기기 분류를 회피하면서도 차별화 포인트를 살리는 핵심입니다.

Part VIII. Agent #3 실시간 건강 모니터링 — 상세 구현 방안 및 회피 전략

1. 회피 전략의 핵심 원리 — "AI 판정 → 사용자 자가 임계치"로 전환

의료기기 분류의 결정적 요인은 "AI 알고리즘이 사용자 데이터를 분석해 자동으로 위험을 판정"하는 행위 자체입니다. 사용자가 직접 임계치를 설정하고 시스템은 그 조건을 단순 비교하는 구조로 바꾸면 의료기기에서 벗어날 수 있습니다.

❌ 의료기기 영역 (식약처 허가 필요)

AI: "심박수 패턴이 부정맥 가능성을 시사합니다. 즉시 병원에 가세요."

▶ AI가 자동으로 의학적 패턴을 인식 → 진단성 결론 → 응급 행동 지시

✅ 비의료 건강관리 영역 (합법)

시스템: "오늘 평균 심박수 95bpm. 사용자 설정 알람 임계치(90bpm)를 초과했습니다. 그래프를 확인하세요."

▶ 사용자가 직접 설정한 임계치 비교 → 단순 통계 표시 → 사용자 판단

2. 합법 구현 아키텍처 (Self-Threshold 모델)

1 Onboarding — 사용자 자가 설정

가입 시 사용자가 직접 알람 임계치 입력. 의료진 권고치는 정보로만 표시 (자동 적용 X). 예: "혈압 150 이상이면 알람" — 사용자가 직접 입력하거나, 가입 시 의사·약사와 상의해서 결정.

2 측정 — 외부 기기 데이터 수집

Apple HealthKit, Google Health Connect를 통해 사용자가 직접 측정·연동한 데이터만 활용. 본 앱은 측정 행위 자체를 하지 않음 (측정은 인증된 의료기기·웨어러블에서 수행).

3 비교 — 단순 임계치 비교 (AI 아님)

if user_threshold < current_value: notify(). 머신러닝·패턴 인식 알고리즘 미사용. 단순 IF 조건문만 사용.

4 알람 — 정보 표시만

"측정값이 사용자 설정 임계치를 초과했습니다"라는 사실 표시. "위험합니다", "병원 가세요" 등 진단·지시성 표현 금지.

3. 의료기기 vs 비의료 건강관리 기준 결정 트리

[기능 설계 시작]



Q1: 의학적 패턴 자동 인식? (예: 부정맥 알고리즘)
YES → 의료기기 (식약처 허가) ← Agent #3 원안
NO ↓

Q2: 사용자가 직접 임계치 설정?
NO (시스템이 자동 판정) → 의료기기 가능성 높음
YES ↓

Q3: 측정값을 단순 비교만 하는가?
NO (AI 추론 포함) → 의료기기 가능성 있음
YES ↓

Q4: 출력에 진단·처방 표현 포함?
YES (즉시 병원 가세요 등) → 진단 행위 위험
NO ↓

✅ 비의료 건강관리 영역 ← Agent #3 회피 안

4. UX 설계 — 임계치 설정 화면

단계	화면 구성 / 핵심 메시지
① 임계치 입력	"혈압이 어느 값을 넘으면 알림을 받고 싶으세요?" [숫자 입력 필드] 참고 정보: "일반적으로 대만고혈압학회는 140/90 이상을 고혈압으로 분류합니다. 본인에게 맞는 값은 의사와 상의하세요."
② 알림 채널	"본인 알림" / "가족(보호자) 알림" 선택 — 후자는 Agent #4 동의 절차 적용
③ 면책 확인	"본 알림은 측정값 기반 단순 비교이며, 의학적 진단이 아닙니다. 위급 시 119에 전화하세요." [동의 체크박스]

5. 알림 메시지 표현 — Before / After

상황	❌ 위반 표현	✅ 합법 표현
혈압 150 측정 시	"혈압이 위험합니다. 즉시 병원에 가세요."	"오늘 측정 혈압 150. 사용자 알림 임계치 (140)를 초과했습니다."
심박 110 측정 시	"빈맥 가능성이 있습니다."	"심박수 110. 평소(70~85) 대비 높게 측정되었습니다."
지속적 이상치 감지	"부정맥이 의심됩니다."	"최근 7일간 평소 범위 외 측정 5회. 의료진과 상담을 고려해보세요."

6. 학생 프로젝트 단계의 권장 안

8주 프로젝트 범위 권장

Agent #3을 정식 구현하지 않고 **"자가 임계치 알림 데모"로 시연**하되, 발표에서는 "본격적인 실시간 위험 감지는 SaMD(소프트웨어 의료기기) 허가가 필요한 영역으로, 회사가 사업화 단계에서 식약처 허가를 받은 뒤 정식 출시할 수 있는 차세대 기능"으로 포지셔닝하면 오히려 법적 리스크를 정확히 인식한 팀이라는 인상을 줄 수 있습니다.

Part IX. Agent #4 가족 케어 — 동의 UX 상세 설계

1. 회피 전략의 핵심 원리 — "포괄 동의 → 항목별 별도 동의"

개인정보보호법 § 23은 민감정보(건강정보)를 다른 동의와 **별도**로 동의받을 것을 요구합니다. "가족 케어 가입 = 모든 정보 공유 동의"는 위법이며, 5년 이하 징역 또는 5천만원 이하 벌금에 매출액 3% 이내 과징금까지 부과됩니다.

❌ 위법 구현 (포괄 동의)

체크박스 1개:

☐ 가족 케어 서비스 이용약관 및 개인정보 처리에 동의합니다.

▶ "동의" 한 번에 복약·진료기록·건강지표·일정 모두 공유
→ 위반

✅ 적법 구현 (항목별 별도 동의)

체크박스 다수, 각 항목 독립:

- ☐ 일반 이용약관 (필수)
- ☐ 복약을 공유 (선택)
- ☐ 진료기록 공유 (선택)
- ☐ 건강 지표 공유 (선택)
- ☐ 일정 공유 (선택)

▶ 각 항목별 동의 거부해도 서비스 이용 가능

2. 동의 흐름 시퀀스 다이어그램



3. 동의 화면 와이어프레임 (한 화면씩)

화면 ① — 동의 안내 (정보 제공)

 가족 케어 — 동의 안내

자녀(보호자)에게 어떤 정보를 공유할지 **직접** 선택할 수 있습니다.
체크하지 않은 항목은 **절대 공유되지 않습니다**.

공유한 정보는 자녀의 화면에서만 보이며, 외부에 공개되지 않습니다.
언제든지 설정에서 동의를 **즉시 철회**할 수 있습니다.

[다음] 버튼

화면 ② — 항목별 동의 (별도 체크)

공유할 항목을 선택하세요 (선택)

☐ **복약률 정보** (민감정보)

자녀에게 보일 내용: "이번 주 복약률 86%"

▶ 미리보기 | ▶ 자세히 보기

☐ **진료기록 요약** (민감정보)

자녀에게 보일 내용: "최근 진료: 2026.04.20 내과"

▶ 미리보기 | ▶ 자세히 보기

☐ **건강 지표** (민감정보, 본인 측정값)

자녀에게 보일 내용: "오늘 혈압 130/85"

▶ 미리보기 | ▶ 자세히 보기

☐ **병원 일정** (일반 정보)

자녀에게 보일 내용: "다음 진료: 2026.05.15"

▶ 미리보기 | ▶ 자세히 보기

※ 모든 항목은 거부할 수 있으며, 거부해도 가족 케어 기능을 일부 사용할 수 있습니다.

[동의 완료] 버튼

4. 동의 능력 확인 절차 (인지장애 고려)

고령자·치매 환자가 본인 판단 능력 없이 동의하는 사례를 방지하기 위한 절차입니다.

절차	방법	법적 근거
① 본인 인증	휴대전화 본인 인증 + 생년월일 확인	본인 동의 의사 확인
② 동의 능력 자가 확인 안내	"본인은 이 동의의 의미를 충분히 이해하셨나요?" 체크박스	의사 능력 확인
③ 의사·금치산 선고 정보 입력	"법정대리인 동의가 필요한 분이신가요?" 선택	제한능력자 보호
④ 정기 재동의 (6개월마다)	알림 발송하여 동의 의사 재확인	지속적 의사 확인

5. 동의 데이터베이스 스키마 (구현 예시)

```
-- 동의 이력 테이블 (감사 로그용 - 영구 보관)
CREATE TABLE consent_records (
  id BIGSERIAL PRIMARY KEY,
  user_id UUID NOT NULL,          -- 정보주체 (부모님)
  family_member_id UUID NOT NULL, -- 보호자 (자녀)
  consent_type VARCHAR(50) NOT NULL, -- 'medication', 'medical_record', etc.
  is_consented BOOLEAN NOT NULL,
  consented_at TIMESTAMPTZ NOT NULL,
  revoked_at TIMESTAMPTZ,
  consent_version VARCHAR(10),    -- 약관 버전
  ip_address INET,               -- 동의 IP (감사 추적)
  device_id VARCHAR(100),
  created_at TIMESTAMPTZ DEFAULT NOW()
);

-- 동의 변경 시 절대 UPDATE 하지 않고 새 행 INSERT (감사 추적)
-- 예: 복약을 동의 → 1행 INSERT
-- 동의 철회 시 → 새로운 행 INSERT (revoked_at 채움, is_consented=false)

CREATE INDEX idx_consent_active ON consent_records
  (user_id, family_member_id, consent_type)
  WHERE revoked_at IS NULL;
```

6. 위반 시 처벌 — 회사 차원의 최대 리스크

⚠ 가족 케어 동의 위반 시 처벌

개인정보보호법 § 23 위반 시:

- **형사처벌:** 5년 이하 징역 또는 5천만원 이하 벌금 (책임자 개인 처벌)
- **행정처벌:** 매출액 100분의 3 이내 과징금 (회사 처벌)
- **2024년 매출 149억 원 기준 → 최대 4.47억 원 과징금 가능성**
- 추가로 동의받지 않은 민감정보 유출 시 정보주체 1인당 손해배상 책임

가족 케어 기능은 작은 UX 결함만으로도 회사 전체에 큰 법적 리스크가 되므로, **법무 검토 1순위 기능**입니다.

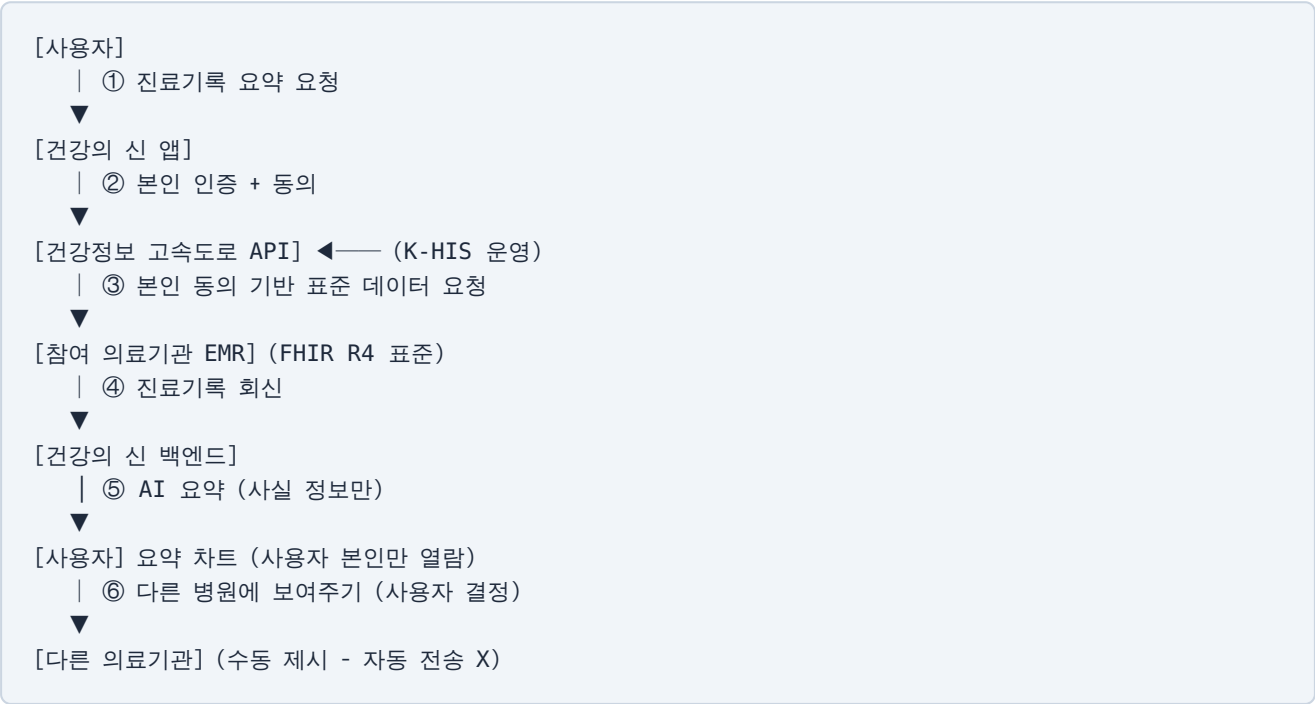
Part X. Agent #6 진료기록 요약 — 건강정보 고속도로 연동 설계

1. 합법 구현의 유일한 경로 — 마이데이터 채널

의료기관 EMR에 직접 접근하는 것은 의료법·개인정보보호법 위반입니다. 유일한 합법 경로는 **한국보건의료정보원(K-HIS)이 운영하는 '건강정보 고속도로'(MyHealthway)** API를 통한 마이데이터 채널 사용입니다.

항목	내용
운영 기관	한국보건의료정보원 (K-HIS)
현재 참여 의료기관	2025년 기준 상급종합병원 47개 전체 + 종합병원·병의원 800여 곳
제공 데이터 (12종)	진단내역, 약물처방내역, 진단·병리검사, 수술내역 등 113개 항목
표준 프로토콜	HL7 FHIR R4 + KR Core (한국 의료정보 표준)
인증/보안	ISMS-P 인증 필수, 본인 동의 기반 전송
레몬헬스케어 위치	이미 LDB-E 플랫폼으로 사업 참여 중 → 합법 구현 가능성 가장 높음

2. 데이터 흐름 아키텍처



3. AI 요약 시 표현 가이드 (진단 vs 정보)

분류	❌ 위반 표현 (진단)	✅ 합법 표현 (사실 요약)
진단명 추론	"이 환자는 당뇨 전 단계 가능성이 높습니다"	"최근 검사: HbA1c 6.2% (2026.04.10)"
처방 변경 해석	"고혈압이 악화되어 약이 변경되었습니다"	"2026.03.15 혈압약 처방 변경 (A제 → B제)"
위험도 평가	"심혈관 질환 위험도가 높습니다"	"최근 3개월 진료 횟수: 내과 3회, 심장내과 1회"
치료 권고	"식이 조절이 필요합니다"	"최근 식단·영양 상담 권유 기록 있음 (2026.04.20)"

4. AI 요약 프롬프트 설계

당신은 환자의 진료기록을 사실 그대로 요약하는 어시스턴트입니다.
다음 규칙을 절대 위반하지 마세요.

절대 금지

- 진단명 추론 (입력 데이터에 없는 질병명 사용 금지)
- 위험도 평가 ("위험합니다", "악화되었습니다" 등)
- 치료 권고 ("00하세요", "약을 바꾸세요")
- 의료적 해석 ("이 검사 결과는 00를 의미합니다")

의무

- 입력 데이터에 명시된 사실만 요약
- 날짜·수치·기관명 정확히 표시
- 의료진의 코멘트는 "의료진 메모: " 형태로 인용
- 끝에 "본 요약은 다른 진료에 참고용이며, 정식 진단·처방은 의사 권한입니다" 부착

입력: FHIR 표준 진료기록 (JSON)

출력 템플릿:

[기간] 최근 3개월 (2026.02.08 ~ 2026.05.08)

[진료 횟수] 내과 3회 / 안과 1회

[주요 검사 결과]

- 2026.04.10 HbA1c 6.2% (○○병원)
- 2026.04.10 혈압 130/85 (○○병원)

[처방 변경]

- 2026.03.15 혈압약 변경 (의료진 메모: 부작용으로 변경)

[다음 예약] 2026.05.20 내과 (○○병원)

본 요약은 다른 진료 시 참고용이며, 정식 진단·처방은 의사 권한입니다.

5. "본인만 열람" 원칙의 기술적 구현

요약본은 사용자 본인만 열람 가능하며, 다른 의료기관에 자동 전송하지 않습니다. "보여주기"는 사용자가 다른 병원에서 화면을 직접 보여주거나 PDF로 출력해서 가져가는 방식입니다.

시나리오	구현 방법	법적 평가
본인 화면 표시	앱 내 요약 카드 / PDF 출력	✅ 합법
다른 병원에 보여주기	사용자가 화면을 직접 의사에게 제시	✅ 합법 (수동 제시)
QR 코드로 의료진 단말기에 전송	의료진의 단말 → 일회성 토큰 인증	⚠ 사용자 매번 동의 필요
건강의 신 → 다른 병원 EMR 자동 전송	구현 금지	❌ 위법 (제3자 자동 제공)

6. 학생 프로젝트 단계의 구현 권장

💡 8주 프로젝트 범위

실제 건강정보 고속도로 API 연동은 의료기관·K-HIS와의 정식 계약이 필요하므로 학생 프로젝트 8주에는 어렵습니다. 대신 **가짜 진료기록 데이터(샘플 FHIR JSON)**를 사용한 **시연 프로토타입**으로 구현하고, 발표에서는 "실제 운영 시 회사가 보유한 LDB-E 플랫폼 → 건강정보 고속도로 API 연동으로 합법 구현 가능"이라는 아키텍처 비전으로 제시하는 것이 권장됩니다.

Part XI. 종합 권고 및 단계별 로드맵

1. 학생 프로젝트 단계 (2026.05 ~ 2026.06.24, 8주)

Agent	8주 내 구현 권장 범위	발표 메시지
#1 영양제·복약 분석	3단 정보 카드 (Layer 1+2 까지) + 면책 고지	"AI가 결론을 내리는 게 아니라 분산된 공공 정보를 큐레이션"
#2 복약·일정 관리	전체 구현 (가장 안전)	표준 알람 기능
#3 실시간 모니터링	자가 임계치 알림 데모만	"본격적 위험 감지는 SaMD 허가 후 정식 출시"
#4 가족 케어	항목별 별도 동의 UX 정식 구현	차별화 포인트로 강조
#5 리워드	건강 점수 화면 + 일반 경품(도서·기프트콘)	건강의 신 연동 비전
#6 진료기록 요약	샘플 FHIR JSON으로 시연 프로토타입	"LDB-E 플랫폼 활용 비전"

2. 회사 본격 출시 단계 (Year 1 ~ Year 3)

시기	필요 절차	관련 Agent
Year 1 Q1	비의료 건강관리서비스 인증 시범사업 신청	#1, #2, #3 (자가임계치)
Year 1 Q2	ISMS-P 인증 추진	전체 (필수 인프라)
Year 1 Q3	디지털의료·건강지원기기 신고 (2026.01.24 시행)	#1, #3
Year 1 Q4	건강정보 고속도로 정식 활용기관 등록	#6
Year 2 ~	Agent #1·#3 정식 구현 시 SaMD 허가 검토 (GMP + 임상시험)	#1, #3 (고도화)
Year 2 ~	일차의료 만성질환관리 사업 연계	#1 (만성질환 특화 강점)

3. 핵심 결론

발표에서 강조할 3대 메시지

- 법적 인식이 있는 팀:** "Agent #1·#3은 디지털의료제품법상 SaMD 분류 가능성을 인지하고, 학생 프로젝트 단계에서는 회피 전략을 적용해 정보 큐레이션·자가 임계치 모델로 구현. 정식 출시는 식약처 허가 후 진행 권장."
- 회사 자산을 활용하는 팀:** "Agent #6은 회사가 이미 참여 중인 LDB-E + 건강정보 고속도로 인프라를 활용 하면 합법 구현 가능. 단순 학생 아이디어가 아닌 회사 전략과 정합."
- 차별화는 합법성에서:** "Agent #4 가족 케어의 항목별 별도 동의 UX는 단순한 컴플라이언스 준수가 아니라, 만성질환자·고령자가 안심하고 사용할 수 있는 차별화 포인트."

⚠️ 면책 고지 (Disclaimer)

본 보고서는 학생 팀의 자체 법률 검토이며, **법무 자문을 대체하지 않습니다**. 정식 출시 전 법률 전문가·의료자문 위 검토가 필수이며, 본 보고서의 평가는 2026.05.08 시점의 법령에 기반합니다. 추후 법령 개정 시 재검토가 필요합니다.

본 보고서는 다음 자료에 기초하여 작성되었습니다:

법령·가이드라인

- 의료법, 약사법, 건강기능식품법, 개인정보보호법 (국가법령정보센터)
- 디지털의료제품법 (2025.01.24 시행) — 식품의약품안전처
- 디지털의료기기 관련 가이드라인 6종 (2025.05.07 제·개정) — 식약처
- 비의료 건강관리서비스 가이드라인 및 사례집 2차 (2022.09) — 보건복지부
- ISMS-P 인증제도 안내서 (2024.07) — 한국인터넷진흥원

참고 시스템·플랫폼

- 건강정보 고속도로 (MyHealthway) — 한국보건 의료정보원
- 의약품 안전사용 정보(DUR) — 건강보험심사평가원
- 식약처 의약품안전나라 / 식품안전나라

본 프로젝트 내부 자료

- 레몬헬스케어_건강의신_기업프로젝트_과제계획서_v1.2 (2026.05.08)
- 레몬헬스케어_프로젝트_사전준비_통합보고서 (2026.04.28)
- 10-compliance-checklist.md (Lemon-Aid 팀 작성)
- lemon_healthcare_ai_agent_final.pdf — 본 평가 대상 기획안

작성: Lemon-Aid 팀 (경북대학교 KDT AI/빅데이터 전문가 양성 과정)

버전: v1.0 / 2026.05.08

문의: 본 평가에 대한 의견 및 보완 요청은 팀 내부 채널로 회신 바랍니다.